Capstone II

Deliverables (Week 1)

Role	Deliverable	What it contains
Founders	Decision log (6 items)	Each decision, the choice made, and the reason. Includes the chosen cloud platform and the lawyer booking.
Founders	Feature "done" definitions	One line per core feature, written as a test (see below).
Analyst	Demo scenario document	Attack story step by step, the evidence each step leaves behind, the systems involved, and the expected findings.
Analyst	SOP outline	Headings only for the 5-step flow: intake, triage, collection, analysis, reporting.
Engineer	Architecture draft	One high-level diagram (components and data flow) and one low-level diagram (tools, hosts, storage, where evidence moves).
Engineer	Environment ready	VM, server, repo, and tool list confirmed, with each tool's license checked.
Coordinator	Interview kit	5-8 questions and a target list of 8-10 contacts.
Coordinator	Intake and onboarding map	Intake form fields and the onboarding steps (NDA, SLA, payment, authorization).

Decision logs

- Service scope : Forensics, Containment, Insurance Backup Document Report, Monthly checkup (Package) and Basic Log Monitoring (Package).
- Using Standard for court readied documents : ISO/IEC 27037 which Guides the initial handling of digital evidence. This covers the identification, collection, acquisition, and preservation of digital media and devices so data integrity is not compromised.
- Walk-in Client SLA : Start Clock once deposit completed.
- Pricing On Package Can Decide Later.
- Legal Review : Rent out legal lawyers to examine and make sure the established documents are legit and align with regulation of both standards.

Features

There are 3 categories : Prepare (Before Incident), Respond (During Incident), Recover and Report (After Incident).

Prepare			
Add-on	**Client gets**	**Effort**	**Advice**
Compromise assessment	A fixed-price "are we already breached?" sweep	Medium	**Launch.** Best entry product, since the big firms all sell one
Log readiness setup	Audit logging turned on (M365, Google, AWS, Windows) so evidence exists	Low	**Launch**
Pre-staged collector	Collection kit installed and allowlisted in advance	Low	**Launch.** Avoids antivirus clashes during a crisis
SME starter package	Readiness kit plus a basic IR policy template	Low	**Launch**
Cost-of-incident calculator	Web page where owners estimate loss	Low	**Launch as a free lead magnet**, not a paid add-on
Cyber readiness assessment (full)	Deeper review beyond the onboarding questionnaire	Medium	Later
Tabletop exercise	Simulated incident to train staff	Medium	Later
Phishing simulation	Monthly test emails (GoPhish)	Medium	Later
Leaked-credential alerts	Notice when staff emails appear in breach dumps	Medium	Later. Check each source's terms
Workshops and training	Paid half-day sessions	Medium	Later
vCISO advisory	Ongoing strategic guidance	High	Not yet. Long-term only
Telegram Malicious Message Checking	Can use the telegram bot to check file via telegram from our services	Medium	Per package

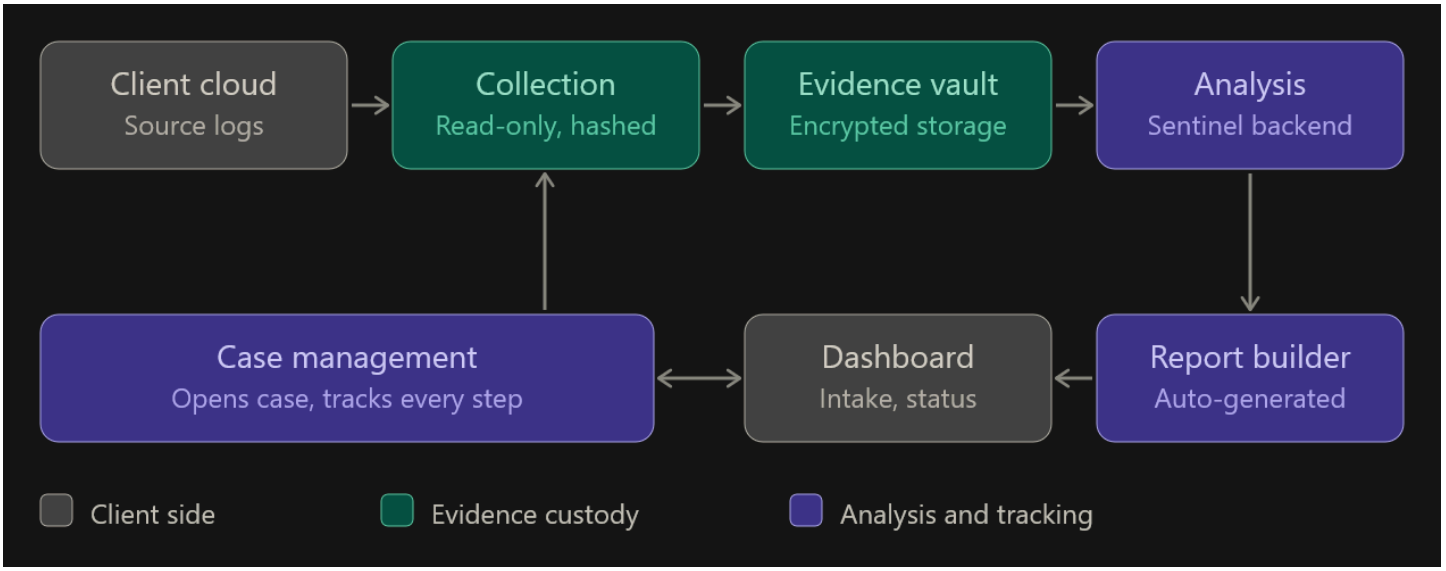
Respond			
Add-on	**Client gets**	**Effort**	**Advice**
Cloud evidence collection	AWS, M365, or Google logs pulled through the API	Medium	**Launch.** It is your demo scope
Evidence collection only	Collection without the full investigation	Low	**Launch.** Already priced at $500
Report from existing evidence	Report built from evidence the client already holds	Low	**Launch.** Already priced at $300
Messenger or Telegram intake	Report an incident from chat	Medium	**Launch manually** (staff opens the case), then automate later
Priority response upgrade	A faster P1 window, for example 2h instead of 4h	Medium	Later. Only promise what four people can cover

Recover and Report			
Add-on	**Client gets**	**Effort**	**Advice**
Post-incident re-check	Scan 30 days after closure plus an "all clear" letter	Medium	**Launch.** Reuses your kit and turns clients into subscribers
Local compliance reporting	Report mapped to NBC rules, with a Khmer summary	Medium	**Launch for fintech only, after the lawyer review.** The mapping is not proven yet
Notification and comms pack	Draft notices for regulators, customers, and staff (Khmer and English)	Medium	Later. Drafts only, no legal guarantee
Insurer-ready report and cost pack	Evidence summary and cost sheet for claims	Low	Later. First step toward insurer partnerships

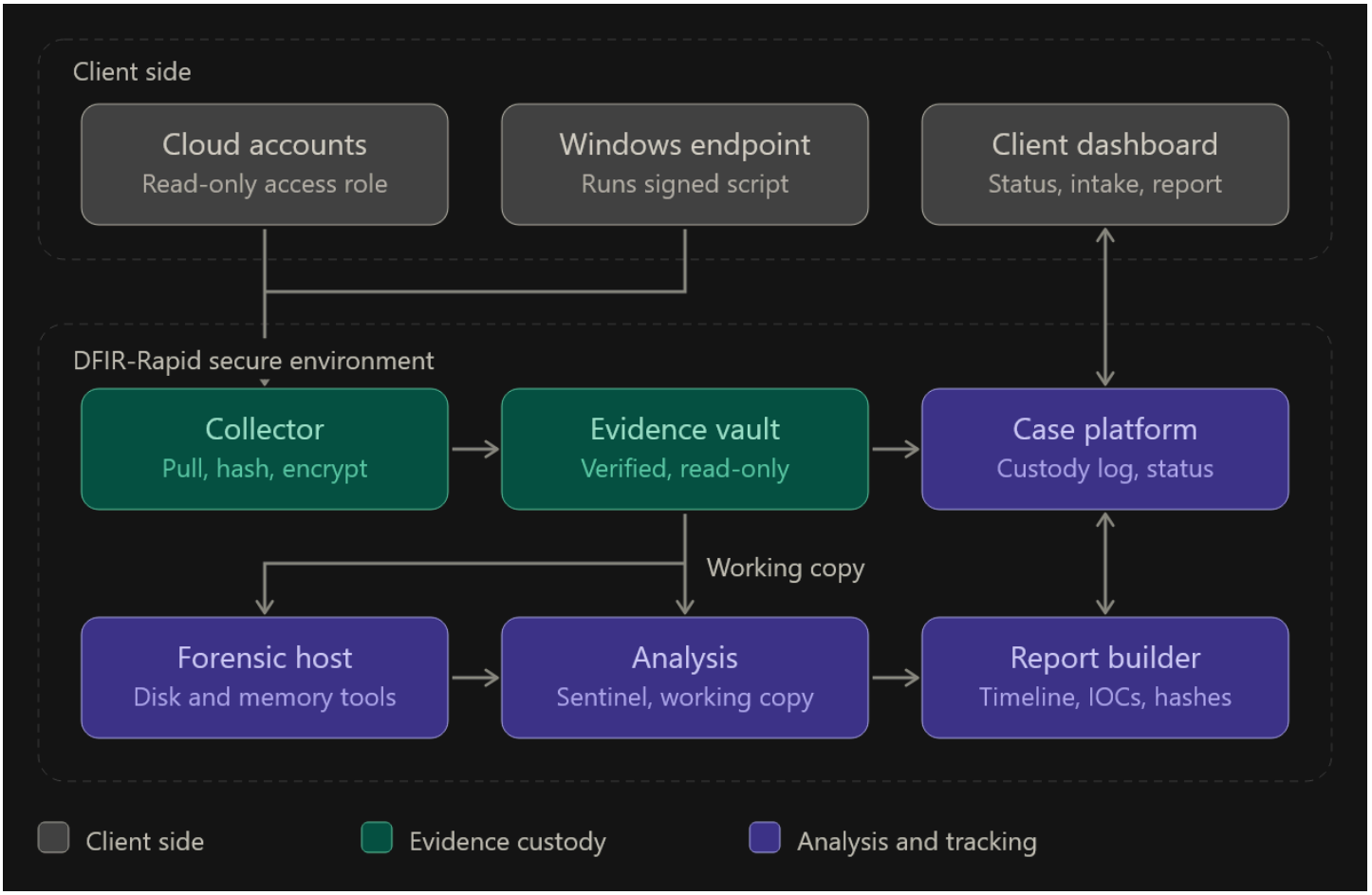
Additional Information

Enterprise example	What to copy	Startup version
Mandiant	Prepaid hours can be repurposed to assessments, tabletops, and training	Unused credits can buy proactive add-ons
CrowdStrike	Selectable response time, with more committed hours lowering the rate	Offer a priority response upgrade once you have staff for it
Unit 42	Credit tiers with a usage-history portal	Credits dashboard (a core feature)
Blackpanda	Fixed cost, collection tools shipped in advance, local language	Pre-staged collector, Khmer reports

Portal Structure



High level Structure



Low Level Structure

The Basic Workflow : Collect -> Store -> Copy -> Analyze (Forensics) -> Track -> Deliver

1. Collect : the cloud is pulled through a read-only role and the endpoint uses a signed script. Both land at the collector where everything is hashed on arrival and encrypted.
2. Store : the vault verifies each hash and keeps the originals read-only. Nobody analyzes the originals.
3. Copy : only a working copy leaves the vault. It goes to the forensic host (disk and memory) and to the analysis workspace (cloud logs and timeline).
4. Track : the case platform records each hash, who touched what, and the status.
5. Deliver : the report builder pulls the hash list and status from the case, and the finished report appears on the dashboard.

Standard of Procedure

No	Step	Owner	Key actions	Output
0	Pre-engagement	Coordinator	Signed NDA, authorization listing the systems in scope, named contact, collection role or script allowlisted	Authorization on file
1	Intake and triage	Coordinator, Analyst	Open case with a unique ID, rate priority (P1-P4), assign one investigator, start the SLA clock after authorization and deposit	Case plus priority
2	Containment guidance	Analyst	Tell the client to isolate machines and not reboot or wipe, revoke sessions or disable accounts, preserve logs. Never disable their security tools without written approval	Containment checklist signed off
3	Evidence collection	Analyst, Engineer supports	Collect cloud logs and endpoint artifacts, hash at source, upload, verify on receipt, log custody	Hash manifest, custody log
4	Analysis	Analyst	Ingest the working copy, build the timeline, identify IOCs, root cause, and affected data, then check findings against raw logs	Findings and timeline
5	Reporting	Analyst writes, second reviewer checks	Generate the report (summary, timeline, evidence list, root cause, impact, recommendations), peer review, publish on the dashboard, walk the client through it	Unified Forensic Report
6	Closure	Coordinator, Founders	Client confirms receipt, evidence retained 12 months then deleted, deletion certified, lessons noted	Closed case

Important Note :

- Work only on copies, and hash everything.
- Only the assigned investigator touches the evidence.
- Log each action in the case.
- Write in the report only what the evidence supports, with limits stated.

Scenario Demonstration

Source: CourseCadt

Compliance and Regulation

- **ISO/IEC 27037** : Evidence collection and preservation.
- **NIST SP 800-61 Rev. 3** : Incident Response Recommendations and Considerations for Cybersecurity Risk Management.
- **MITRE ATT&CK** : Timelines and IOCs in the report.
- **ISO/IEC 27001** : Apply relevant controls.

Important Documents

Legal foundation

1. **Business registration papers**: MoC certificate, GDT tax/patent registration, Ministry of Labour notification.

Client-facing (sign before any case)

2. **Master Services Agreement (MSA)**: fees, liability cap, governing law (Cambodia).
3. **Authorization & Scope Letter**: named signer and systems in scope. This is your legal shield.
4. **Mutual NDA**.
5. **SLA**: add the walk-in clock rule (starts after authorization and deposit).
6. **Data Processing Agreement (DPA)**: what you collect, where it's stored, retention, access.
7. **Privacy Notice**: for your website, intake form and contact data.

Internal (proves you practice what you sell)

8. **Information Security Policy**: encryption, MFA, least privilege.
9. **Evidence Handling SOP + Chain of Custody form**: your core quality document.
10. **Staff Confidentiality Agreement**: for every analyst.
11. **Your own Incident Response Plan**: what you do if *you* are breached.

Survey

Group	Target	Why
1. SME owners / IT managers (e-commerce, SaaS, NGOs)	15-20	Your buyers: pricing, urgency, willingness to pay

2. Fintech / FMI staff (compliance or IT)	5-8	NBC rules, data location, reporting duties
3. MSPs / local IT companies	5-8	Partner and referral channel; they see incidents first
4. Lawyers or insurers	3-5	Evidence requirements, contract and liability wording
5. Other DFIR / security professionals	3-5	Technical validation of your toolset and report

Groups 1 and 2: SMEs and fintech

1. Company size and sector? Do you have any in-house IT or security staff?
2. Have you had a security incident in the last 2 years? What happened and what did it cost (time and money)?
3. Who did you call, and how long until help arrived?
4. If you had an incident today, who would you call?
5. Rank what matters most: response speed, price, local language, report quality, legal/insurance support.
6. How much would you pay per incident ? (Range)
7. Would you pay a monthly retainer for a guaranteed response? Which range? (Under $200 / $200-500 / $500+)
8. Would you sign an NDA and authorization online in advance ? What worries you about sharing logs or devices ?
9. Where must your data be stored ? (Cambodia only / ASEAN / no preference.)
10. Do you have any breach-reporting duties (NBC, clients, insurers)? Do you know how to meet them?
11. Would you prefer a Khmer report summary?
12. Which add-ons interest you? (Compromise check, log setup, Khmer templates, insurer-ready report, monthly check-up.)

Group 3: MSPs

1. What do you do today when a client has a breach?
2. Would you refer or white-label a DFIR service? What commission or arrangement works?
3. What would make you trust a new provider?

Groups 4 and 5: lawyers, insurers, professionals

1. What evidence documentation do you need for a claim or case?
2. What's missing from typical forensic reports?
3. Review our sample report and tool list: what would you change?

Your open decision	Question that answers it
Pricing inconsistency	Q6-7 (willingness to pay)
24/7 monitoring vs forensics-only	Q3-5 (what they actually want)
"60% faster / 75% cheaper" claim	Q2-3 (current response time and cost, your baseline)
Court-ready wording	Groups 4-5
Which add-ons to build	Q12

Context